



AWS Golden Jacket Project Report

Project: Cross-Account IAM Automation & Confused Deputy Protection **Target Certification:** AWS Certified Developer - Associate (DVA-C02)

1. Executive Summary & Business Problem

Business Problem: Enterprises operating multi-account AWS environments need secure, automated methods to access resources across boundaries without generating long-term static credentials (IAM Access Keys). Specifically, an orchestration process in a central account needs to read S3 bucket metadata in target accounts without violating security best practices.

Solution: Implemented a secure cross-account STS `AssumeRole` architecture. Using Infrastructure as Code, we provisioned a Target Execution Role with a strict Trust Policy utilizing `sts:ExternalId` to mitigate the Confused Deputy vulnerability, and a Source User with targeted `AssumeRole` permissions.

2. Architecture Overview & Services Used

The architecture relies entirely on native AWS Identity and Access Management and Security Token Service constructs:

- **AWS IAM:** Used to define Roles, Users, Trust Policies, and Permissions Policies.
- **AWS STS:** Core mechanism facilitating `sts:AssumeRole` to issue short-lived credentials.
- **Amazon S3:** Target service queried using `s3:ListAllMyBuckets`.
- **AWS CloudFormation:** Used to define the cross-account architecture reproducibly.

Rationale: We chose Role Assumption over Resource-Based Policies (like S3 Bucket Policies) because Role Assumption centralizes identity management. Instead of updating 50 S3 bucket policies across an organization, we update one Role Trust Policy.

3. Validation Checklist & Failure Scenarios Tested

Component Tested	Scenario	Result
Trust Policy Boundary	Source User lacks <code>sts:AssumeRole</code> policy but Target trusts Source Root.	Access Denied (PASS)
Confused Deputy Protection	Source User provides incorrect <code>ExternalId</code> .	Access Denied (PASS)
S3 Global API Constraint	Permissions policy scopes <code>s3:ListAllMyBuckets</code> to specific bucket ARN.	IAM Policy Error (PASS)
Successful Orchestration	Valid Keys, Valid Target Role ARN, Valid <code>ExternalId</code> .	STS Credentials Issued (PASS)

Production Failure Engineering Insight: When `sts:ExternalId` fails, AWS STS deliberately returns a generic `AccessDenied` error rather than a specific "External ID Mismatch" error. This prevents attackers from enumerating or brute-forcing whether an IAM Role requires an External ID.

4. DVA-C02 Certification Intelligence

Domain 4: Security and Compliance (20% of exam)

This project heavily targets the Developer Associate exam. You must memorize the following concepts to achieve a 900+ score:

- **The Confused Deputy Problem:** A scenario where a trusted entity (deputy) is manipulated to perform an action on behalf of an attacker. In cross-account roles, always use `sts:ExternalId` to verify the calling party.
- **Trust Policy vs. Permissions Policy:** * *Trust Policy:* Defines **WHO** can assume the role (Principals, External IDs).
 - *Permissions Policy:* Defines **WHAT** the assumed role can do.
- **S3 List Constraints:** `s3:ListAllMyBuckets` is an account-level API and cannot be restricted to a specific Resource ARN; it MUST be `*`.
- **STS Session Duration:** By default, STS sessions last 1 hour, but can be configured up to 12 hours.

5. Principal Architect / Interview Preparation

Q: "We have an EC2 instance in Account A that needs to read an S3 bucket in Account B. Should we use an IAM Role cross-account trust or an S3 Bucket Policy?" *Answer:* It depends on the scale. An S3 bucket policy is simpler for a 1-to-1 relationship because you don't need code to assume a role. However, if Account A needs to access DynamoDB, S3, and SQS in Account B, using a Cross-Account IAM Role is vastly superior, as it centralizes all access management into a single role.

6. Observation Library

1. **STS behaves as an identity bridge** because it translates long-term caller identity into short-lived operational credentials across logical boundaries.
2. **S3 `ListAllMyBuckets` requires global scope** because it queries the account control plane, not a regional data plane.

Golden Jacket Progress: 1 / 100 Projects Completed.